

L9 - O'Reilly Virtual Private Networks 2nd Edition

Estudiante: Mariela Solano Gómez

Carné: 2022437963

Preguntas

1. ¿Qué es un firewall? Comente los tipos existentes en capa 3/4

Un firewall es básicamente un guardia de seguridad que se coloca entre tu red privada e Internet. Todo el tráfico que entra o sale tiene que pasar por él, y el firewall decide si lo deja pasar o lo bloquea según un conjunto de reglas definidas por el administrador. Su trabajo es controlar tanto lo que los de afuera pueden ver de tu red, como lo que los de adentro pueden acceder en Internet.

El tipo de firewall que opera en las capas 3 y 4 (a nivel de direcciones IP y puertos) se llama filtrado de paquetes. Este firewall nunca abre los paquetes para ver qué hay adentro; solo mira la información del encabezado: de dónde viene el paquete, hacia dónde va y por qué puerto. Si el paquete coincide con una regla que lo permite, pasa; si no, se descarta. Existen dos formas de configurarlo: la primera es dejar pasar todo por defecto y solo bloquear lo que se sabe que es peligroso; la segunda es bloquear todo por defecto y solo dejar pasar lo que se autorice explícitamente, lo cual es más seguro pero requiere más mantenimiento.

Una limitación importante de este tipo de firewall es que no puede identificar quién está enviando el tráfico, solo desde dónde viene. Por ejemplo, no puede distinguir si es un empleado o un extraño conectándose desde la misma red. Además, cualquier cambio grande en la red puede obligar a reconfigurar todo el firewall, lo que puede causar errores graves si no se hace con cuidado.

2. ¿Qué es un bastion host?

Un bastion host es una computadora especialmente preparada y reforzada en seguridad que actúa como intermediario entre Internet y la red interna. Es como una caseta de control: todo el tráfico que viene de afuera debe pasar primero por ella antes de llegar a las máquinas internas. Para que funcione bien, se combina con un router que filtra paquetes: el router aplica una regla simple de "bloquear todo", y solo permite el tráfico dirigido específicamente al bastion host.

Lo bueno de este enfoque es que simplifica mucho la administración. Si se agrega una computadora nueva a la red interna, no es necesario cambiar las reglas del firewall, porque el bastion host sigue siendo el único punto de entrada. Sin embargo, su mayor debilidad es que concentra toda la seguridad en un solo lugar. Si un atacante logra tomar el control del bastion host, tendría acceso a toda la red. En redes muy grandes, puede ser necesario tener varios bastion hosts, lo que a su vez complica la administración y convierte a cada uno de ellos en un blanco atractivo para los atacantes.

3. ¿En qué consiste un DMZ?

Una DMZ, o zona desmilitarizada, es una red intermedia que se crea entre Internet y la red interna de una organización, con el objetivo de agregar una capa extra de protección. El nombre viene de las zonas militares neutrales que separan dos bandos enemigos: aquí cumple la misma función, separando el Internet público e inseguro de la red privada.

Para construir una DMZ se usan al menos dos routers. El primero, llamado router exterior, está conectado directamente a Internet y filtra el tráfico antes de que llegue a la red perimetral. El segundo, llamado router interior, separa esa red perimetral de la red interna y aplica las reglas de seguridad más estrictas. Si un atacante logra vulnerar el router exterior, todavía tendría que atravesar el router interior para llegar a la red interna, lo que hace mucho más difícil el ataque. Además, es común usar una técnica llamada NAT en el router interior, que oculta las direcciones reales de las máquinas internas, dificultando aún más que un atacante las ubique y las ataque directamente.

4. ¿Qué es un Proxy server?

Un proxy server es un tipo especial de intermediario que se hace pasar por otra máquina para protegerla. Cuando una computadora interna quiere comunicarse con algo en Internet, en lugar de hacerlo directamente, el proxy toma su lugar: habla con el exterior como si fuera esa máquina, y luego le entrega la respuesta a la máquina original. De esta forma, la identidad y la dirección de las máquinas internas nunca quedan expuestas al exterior.

Un buen ejemplo de para qué sirve es el protocolo FTP, que es especialmente difícil de manejar en un firewall porque usa puertos variables e impredecibles. Al colocar un proxy FTP en la red perimetral, este se encarga de gestionar toda la comunicación con el servidor externo, mientras que las máquinas internas solo hablan con el proxy. Esto evita tener que abrir muchos puertos en el firewall. Es importante entender que un proxy no es una solución de seguridad completa por sí solo; debe usarse junto con otras medidas, como el filtrado de paquetes, para tener una protección más sólida.

5. Explique los diferentes protocolos de VPN

IPSec es el protocolo más importante de todos y sirve como base para la mayoría de las VPNs modernas. Su objetivo es agregar seguridad directamente al protocolo IP, de modo que toda la comunicación en la red sea segura sin necesidad de modificar las aplicaciones. IPSec no impone un algoritmo de cifrado específico, sino que define una estructura flexible que puede usar diferentes métodos según las necesidades. Funciona en dos modos: el modo transporte, que solo cifra el contenido del paquete, y el modo túnel, que cifra tanto el contenido como los datos del encabezado, ocultando incluso quién habla con quién.

ESP (Encapsulating Security Payload) es el componente de IPSec que se encarga del cifrado real de los datos. Envuelve el paquete original en una capa cifrada para que nadie que lo intercepte pueda leer su contenido. Usa algoritmos como DES o Triple DES para hacer esto, y puede viajar dentro de paquetes IP normales, lo que lo hace compatible con redes existentes.

AH (Authentication Header) es el complemento de ESP, pero en lugar de cifrar los datos, se encarga de verificar que el paquete no fue alterado en el camino y que realmente viene de quien dice venir. No ofrece confidencialidad por sí solo, pero puede usarse junto con ESP para tener tanto autenticación como cifrado al mismo tiempo.

IKE (Internet Key Exchange) resuelve un problema muy práctico: ¿cómo se ponen de acuerdo dos computadoras en qué clave usar para cifrar, si la comunicación todavía no es segura? IKE se encarga de

negociar y distribuir las claves de forma segura usando el algoritmo Diffie-Hellman. Además, cambia las claves periódicamente para que, si alguien logra descifrar una clave, no pueda leer toda la comunicación pasada ni futura.

X.509 es un sistema de certificados digitales gestionado por terceros de confianza llamados Autoridades de Certificación. Funciona como un documento de identidad digital: permite verificar que la persona o máquina con la que te estás comunicando es realmente quien dice ser. Es fundamental para la autenticación en entornos IPSec.

LDAP es un protocolo de directorio simplificado que algunas soluciones VPN usan para gestionar la autenticación y los certificados de sus usuarios. Es más fácil de implementar que su versión completa (X.500) y está soportado en sistemas como Windows NT y Novell.

Radius es un sistema de autenticación pensado para uso interno dentro de una organización. Permite verificar la identidad de los usuarios que quieren conectarse a la VPN. Aunque no está formalmente aprobado por el IETF, es el sistema de autenticación más usado en las soluciones VPN disponibles en el mercado.

PPTP (Point-to-Point Tunneling Protocol) es una extensión del protocolo PPP que permite crear un canal seguro de comunicación entre dos computadoras a través de Internet. Es más sencillo que IPSec y funciona bien para conexiones de usuario a red, pero no es tan adecuado para conectar redes enteras entre sí, donde IPSec es la mejor opción.